MITRE ATLAS | AML.CS0018 - Arbitrary Code Execution with Google Colab

Entry Information

ID:
AML.CS0018
Type:
Case-Study
Name:
Arbitrary Code Execution with Google Colab
URL:
https://atlas.mitre.org/studies/AML.CS0018/
Incident Date:
2022-07-01
Target:
Google Colab
Actor:
Tony Piazza

Description

Google Colab is a Jupyter Notebook service that executes on virtual machines. Jupyter Notebooks are often used for ML and data science research and experimentation, containing executable snippets of Python code and common Unix command-line functionality. In addition to data manipulation and visualization, this code execution functionality can allow users to download arbitrary files from the internet, manipulate files on the virtual machine, and so on.

Users can also share Jupyter Notebooks with other users via links. In the case of notebooks with malicious code, users may unknowingly execute the offending code, which may be obfuscated or hidden in a downloaded script, for example.

When a user opens a shared Jupyter Notebook in Colab, they are asked whether they'd like to allow the notebook to access their Google Drive. While there can be legitimate reasons for allowing Google Drive access, such as to allow a user to substitute their own files, there can also be malicious effects such as data exfiltration or opening a server to the victim's Google Drive.

This exercise raises awareness of the effects of arbitrary code execution and Colab's Google Drive integration. Practice secure evaluations of shared Colab notebook links and examine code prior to execution.

Attack Procedure:
[AML.T0017] Develop Capabilities: An adversary creates a Jupyter notebook containing obfuscated, malicious code.
[AML.T0010.001] AI Software: Jupyter notebooks are often used for ML and data science research and experimentation, containing executable snippets of Python code and common Unix command-line functionality.
Users may come across a compromised notebook on public websites or through direct sharing.
[AML.T0012] Valid Accounts: A victim user may mount their Google Drive into the compromised Colab

notebook. Typical reasons to connect machine learning notebooks to Google Drive include the ability to train on data stored there or to save model output files.

```
from google.colab import drive
drive.mount(''/content/drive'')
```

Upon execution, a popup appears to confirm access and warn about potential data access:

> This notebook is requesting access to your Google Drive files. Granting access to Google Drive will permit code executed in the notebook to modify files in your Google Drive. Make sure to review notebook code prior to allowing this access.

A victim user may nonetheless accept the popup and allow the compromised Colab notebook access to the victim''s Drive. Permissions granted include:
- Create, edit, and delete access for all Google Drive files
- View Google Photos data
- View Google contacts

[AML.T0011] User Execution: A victim user may unwittingly execute malicious code provided as part of a compromised Colab notebook. Malicious code can be obfuscated or hidden in other files that the notebook downloads.
[AML.T0035] AI Artifact Collection: Adversary may search the victim system to find private and proprietary data, including ML model artifacts. Jupyter Notebooks [allow execution of shell commands](https://colab.research.google.com/github/jakevdp/PythonDataScienceHandbook/blob/master/notebooks/01.05-IPython-And-Shell-Commands.ipynb).

This example searches the mounted Drive for PyTorch model checkpoint files:

```
!find /content/drive/MyDrive/ -type f -name *.pt
```

> /content/drive/MyDrive/models/checkpoint.pt

[AML.T0025] Exfiltration via Cyber Means: As a result of Google Drive access, the adversary may open a server to exfiltrate private data or ML model artifacts.

An example from the referenced article shows the download, installation, and usage of `ngrok`, a server application, to open an adversary-accessible URL to the victim's Google Drive and all its files.
[AML.T0048.004] AI Intellectual Property Theft: Exfiltrated data may include sensitive or private data such as ML model artifacts stored in Google Drive.
[AML.T0048] External Harms: Exfiltrated data may include sensitive or private data such as proprietary data stored in Google Drive, as well as user contacts and photos. As a result, the user may be harmed financially, reputationally, and more.

References

- Be careful who you colab with — https://medium.com/mlearning-ai/careful-who-you-colab-with-fa8001f933e7